

1. Scenario: A major incident has occurred, and critical business services have been impacted. The incident response team has been working for hours but has not yet resolved the issue. Senior management is asking for regular updates, and pressure is mounting from stakeholders.

Question: What should be the FIRST action of the information security manager in this situation?

- a) Assign additional resources to the incident response team
- b) Immediately report the incident to external regulatory bodies
- c) Ensure communication with senior management is effective and accurate
- d) Shut down all affected systems to prevent further damage

Answer: c) Ensure communication with senior management is effective and accurate

Explanation: The most important responsibility is ensuring effective communication with senior management. Providing accurate updates helps maintain transparency and manage expectations during a critical event. Assigning more resources or shutting down systems may be needed, but the first step is clear communication.

2. Scenario: Your organization is preparing to implement a new enterprise-wide risk management system. During a risk assessment, it is discovered that some critical systems lack proper encryption, and sensitive customer data is at risk.

Question: What is the BEST course of action for the information security manager?

- a) Immediately initiate encryption on all systems
- b) Document the risk and escalate it to senior management
- c) Include the risk in the next quarterly risk review
- d) Shut down the affected systems until encryption is implemented

Answer: b) Document the risk and escalate it to senior management

Explanation: Documenting the risk and escalating it to senior management ensures that it is addressed at the appropriate level. It allows leadership to make informed decisions about risk tolerance and prioritization. Immediate encryption might be necessary but must follow organizational risk management protocols.

3. Scenario: During an audit, it was discovered that certain critical processes do not have up-to-date incident response plans. Your security team is currently understaffed, and resources are stretched thin.

Question: What should the information security manager prioritize?

- a) Hire additional staff to develop new incident response plans
- b) Update the incident response plans for the most critical processes
- c) Perform a risk assessment of the current processes
- d) Defer the updates until resources are available

Answer: b) Update the incident response plans for the most critical processes

Explanation: The priority should be to address the highest risks first by updating the incident response plans for the most critical processes. This approach balances available resources with the need to mitigate potential damage to the business.

4. Scenario: An organization has completed a security risk assessment, identifying multiple high-risk vulnerabilities in the IT infrastructure. The budget for remediation is limited.

Question: What should the information security manager do FIRST?

- a) Remediate all high-risk vulnerabilities immediately
- b) Prioritize vulnerabilities that have the greatest potential business impact
- c) Request additional budget from senior management
- d) Implement compensating controls for all identified vulnerabilities

Answer: b) Prioritize vulnerabilities that have the greatest potential business impact

Explanation: Given limited resources, the information security manager should prioritize vulnerabilities based on business impact. This ensures that critical risks are addressed first, optimizing resource use for the highest benefit.

5. Scenario: A third-party vendor has access to your organization's sensitive data. You discover that the vendor's security practices are inadequate and pose a potential risk to your organization.

Question: What is the BEST course of action?

- a) Immediately terminate the contract with the vendor
- b) Perform a risk assessment and notify senior management
- c) Require the vendor to adopt your organization's security standards
- d) Limit the vendor's access to sensitive data

Answer: b) Perform a risk assessment and notify senior management

Explanation: Performing a risk assessment provides a detailed understanding of the severity of the risk. Senior management needs this information to make informed decisions about the vendor relationship and risk mitigation.

6. Scenario: During a business continuity test, it was found that a critical system did not fail over to its backup as expected, leading to a significant outage.

Question: What should the information security manager do FIRST?

- a) Notify senior management of the failed test
- b) Implement a manual failover process as a backup
- c) Conduct a root cause analysis of the failure
- d) Perform a full risk reassessment of the continuity plan

Answer: c) Conduct a root cause analysis of the failure

Explanation: Conducting a root cause analysis will help identify why the system did not fail over correctly, enabling a targeted solution. Only after understanding the cause should further steps, like notifying management or reassessing risks, be taken.

7. Scenario: An information security audit has revealed a significant number of security controls that are not being followed. However, the organization has not experienced any security breaches.

Question: What should be the information security manager's PRIMARY concern?

- a) The possibility of undetected security breaches
- b) Ensuring that all security controls are followed immediately
- c) Communicating the importance of security controls to staff
- d) Reassessing the effectiveness of current security controls

Answer: d) Reassessing the effectiveness of current security controls

Explanation: If controls are not being followed, they may not be effective or appropriate for the organization's needs. A reassessment will determine whether controls should be adjusted or strengthened and whether user compliance can be improved.

8. Scenario: A global organization is expanding its operations to a country with stringent data protection regulations. The legal team has identified potential compliance issues with the organization's current data handling practices.

Question: What should the information security manager do FIRST?

- a) Ensure that encryption is implemented for all data transfers
- b) Update the organization's privacy policies

- c) Perform a gap analysis against the new regulations
- d) Hire a local consultant to address the compliance issues

Answer: c) Perform a gap analysis against the new regulations

Explanation: Performing a gap analysis identifies the specific areas where the organization's practices do not comply with the new regulations. This is the first step in addressing compliance issues before implementing any specific solutions.

9. Scenario: After implementing a new cloud-based solution, users report that they can access sensitive information without proper authentication. Upon investigation, you discover a misconfiguration in the cloud access controls.

Question: What should be the NEXT step for the information security manager?

- a) Immediately revoke access to the cloud solution
- b) Correct the misconfiguration and review access logs
- c) Notify senior management of the security incident
- d) Implement additional multi-factor authentication

Answer: b) Correct the misconfiguration and review access logs

Explanation: Correcting the misconfiguration will resolve the immediate issue, and reviewing access logs will help assess the potential damage. Afterward, other actions, such as notifying management, can be taken based on findings.

10. Scenario: A company is undergoing a merger, and the information security manager has been asked to integrate the security policies of both organizations. There are significant differences between the two sets of policies.

Question: What is the BEST approach to ensure a smooth integration?

- a) Adopt the policies of the acquiring company
- b) Develop entirely new policies that combine elements of both
- c) Perform a risk assessment to identify critical differences
- d) Implement the stricter set of policies across both organizations

Answer: c) Perform a risk assessment to identify critical differences

Explanation: A risk assessment will help identify which policy differences present the greatest risk to the organization. This allows the information security manager to prioritize areas for alignment and ensure that critical risks are addressed.